FACULTAD DE DEFENSA NACIONAL — FADENA
LICENCIATURA EN CIBERDEFENSA | Tecnología Operativa 2026
UNIDAD 4: CONVERGENCIA, IoT Y RIESGOS EN CIBERDEFENSA

AP N°16 — ACTIVIDAD PRÁCTICA

Análisis Forense de Tráfico MQTT: Broker Inseguro, Reconocimiento por Wildcard y Ataque de Retained Message

Documento de Cátedra N°16 — IoT e IIoT: Protocolos Ligeros y Expansión de la Superficie de Ataque

Tiempo estimado	90–120 minutos	**Dificultad**	Intermedia
Herramienta principal	CloudShark (web, sin instalación)	**Recurso adicional**	Wireshark (opcional, local)
Modalidad	Individual, asincrónica	**Entrega**	Captura de pantalla + respuestas escritas en PDF
Archivo de trabajo	base_tecnica_norte_mqtt_20260601.pcap (provisto por la cátedra en Moodle)	**Documento alineado**	Doc. de Cátedra N°16

ESCENARIO DEL INCIDENTE

Base Técnica Norte es una instalación militar ficticia de mantenimiento de equipos y sistemas de comunicaciones. En los últimos 12 meses implementaron un sistema IIoT de gestión energética: sensores de temperatura y vibración en los tres generadores de emergencia, conectados mediante MQTT a un broker Eclipse Mosquitto centralizado. El Energy Management System (EMS) subscribe a la telemetría y publica setpoints de control.

El 1 de junio de 2026, el técnico de turno observó que el Generador 1 (GEN-01) apagó su grupo de bombeo a las 03:24:15 sin que ningún operador hubiera enviado la orden. Revisando los logs del EMS, no encontró ningún comando de shutdown emitido por el sistema autorizado. El jefe de guardia activó el protocolo de respuesta a incidentes y solicitó al equipo de Ciberdefensa que analice el archivo PCAP capturado automáticamente por el sniffer del switch de la red IIoT.

El archivo PCAP base_tecnica_norte_mqtt_20260601.pcap cubre la ventana horaria 03:15:00 – 03:45:00 del mismo día. Tu tarea como analista es reconstruir la secuencia de eventos, identificar el tipo de ataque y determinar qué vulnerabilidad estructural del broker MQTT lo habilitó.

Topología de red (según inventario de activos)

IP	Rol	Descripción
192.168.10.5	Broker MQTT	Eclipse Mosquitto 2.0.15 — único broker autorizado en la red IIoT de la instalación. Puerto TCP 1883 (sin TLS).

IP	Rol	Descripción
192.168.10.20	EMS (publisher/subscriber)	Energy Management System — sistema autorizado que publica setpoints de control y subscribe a la telemetría de todos los sensores.
192.168.10.30	Sensor-GEN-01	Sensor IIoT de temperatura y vibración del generador 1. Publica al tópico generators/unit1/telemetry. Subscribe a generators/unit1/control para recibir setpoints.
192.168.10.31	Sensor-GEN-02	Sensor IIoT del generador 2. Publica a generators/unit2/telemetry. Subscribe a generators/unit2/control.
192.168.10.32	Sensor-GEN-03	Sensor IIoT del generador 3. Publica a generators/unit3/telemetry. Subscribe a generators/unit3/control.
192.168.10.88	? (no registrada)	IP no registrada en el inventario de activos de la instalación — su presencia en el tráfico capturado ya es una anomalía que debe investigarse.

OBJETIVOS DE APRENDIZAJE

- Decodificar un paquete MQTT PUBLISH con flag RETAIN campo a campo, identificando el Control Packet Type, el Remaining Length, el Topic Name y el Payload JSON.
- Decodificar el byte de Connect Flags de un paquete MQTT CONNECT e identificar la ausencia de credenciales como vector de acceso no autorizado al broker.
- Interpretar tráfico MQTT en CloudShark utilizando filtros específicos del disector Wireshark/MQTT para aislar CONNECT, PUBLISH, SUBSCRIBE y los paquetes con flag RETAIN activo.
- Identificar la presencia de un cliente no autorizado y reconstruir su secuencia de reconocimiento (SUBSCRIBE con wildcard “#”) y de ataque (PUBLISH con RETAIN).
- Vincular las vulnerabilidades estructurales del broker MQTT (Secciones 2.2 y 4 del Doc. N°16) con el mecanismo de cada paso del ataque documentado en el PCAP.
- Proponer la configuración segura del broker y los controles de arquitectura OT/IIoT que habrían prevenido o detectado el incidente.

INSTRUCCIONES GENERALES

1. Descargar el archivo *base_tecnica_norte_mqtt_20260601.pcap* desde la sección AP N°16 en Moodle antes de comenzar.
2. Registrar una cuenta gratuita en CloudShark (**https://www.cloudshark.org**) si aún no se dispone de una. Alternativamente, usar Wireshark instalado localmente.
3. Completar las fases en el orden indicado: primero Predecir (sin PCAP), luego Verificar (con PCAP), luego Comprender.

4. Las capturas de pantalla deben mostrar claramente el filtro aplicado y los resultados. Incluir la URL de CloudShark o el nombre de la captura.
5. Redactar las respuestas en los espacios provistos. Las respuestas de análisis (Fase 3) deben fundamentarse citando el campo específico del Doc. N°16 que respalda cada afirmación.
6. No compartir ni discutir los hallazgos del PCAP con compañeros antes de completar la Fase 1 (Predecir).

FASE 1 — PREDECIR (completar ANTES de abrir el archivo PCAP)

PROPÓSITO

Activar el conocimiento previo y formular predicciones antes del análisis. Completar esta fase sin ver el PCAP permite contrastar lo que se espera con lo que realmente contiene la captura, ejercitando el razonamiento analítico del analista forense. Las predicciones incorrectas son tan valiosas como las correctas: revelan los supuestos que el protocolo rompe.

Tarea 1.1 — Decodificación de paquetes MQTT

Los siguientes dos paquetes fueron capturados en la red IIoT de Base Técnica Norte. Decodificar cada campo completando las tablas de análisis. Los campos en fondo azul claro requieren cálculo o interpretación; los demás son lectura directa.

Parte A — Paquete MQTT PUBLISH (con flag RETAIN activo)

Este paquete fue enviado por la IP 192.168.10.88 al broker (192.168.10.5) puerto TCP 1883 a las 03:22:47.

```
31 2C 00 18 67 65 6E 65 72 61 74 6F 72 73 2F 75 6E 69 74 31 2F 63 6F 6E 74
72
6F 6C 7B 22 63 6D 64 22 3A 22 53 48 55 54 44 4F 57 4E 22 7D

Paquete MQTT PUBLISH capturado en red IIoT — 46 bytes (hex)
```

Bytes (hex)	Campo	Dec / ASCII	Descripción / Análisis
31	Fixed Header		Indicar: Control Packet Type (bits 7–4) = ? • DUP (bit 3) = ? • QoS (bits 2–1) = ? • RETAIN (bit 0) = ? ¿Qué significa RETAIN=1 para el broker?
2C	Remaining Length		¿Cuántos bytes siguen al encabezado fijo? Verificar: 2 (Topic Length field) + Longitud del tópico + Longitud del payload = Remaining Length.
00 18	Topic Name Length		Valor decimal: ? bytes. Este es el largo del nombre del tópico que sigue a continuación.
67 65 6E 65 72 61 74 6F 72 73 2F 75 6E 69 74 31 2F 63 6F 6E 74 72 6F 6C	Topic Name		Decodificar en ASCII. ¿Qué proceso o subsistema controla este tópico? ¿Es un tópico de telemetría o de control?
7B 22 63 6D 64 22 3A 22 53 48 55 54 44 4F 57 4E 22 7D	Payload (JSON)		Decodificar en ASCII. ¿Qué consecuencia física sobre el generador produce este comando? ¿Considera que el Sensor-GEN-01 obedece

Bytes (hex)	Campo	Dec / ASCII	Descripción / Análisis
			automáticamente cualquier mensaje en este tópico?

Pregunta complementaria A.1: Explicar por qué el flag RETAIN=1 convierte este paquete en un vector de ataque persistente, a diferencia del mismo mensaje enviado con RETAIN=0. Vincular con la función MQTT «Retained messages» de la Tabla de la Sección 2.2 del Doc. N°16.

Respuesta A.1 — Flag RETAIN y persistencia del ataque

Pregunta complementaria A.2: ¿El broker MQTT puede verificar si el emisor de este PUBLISH es un cliente autorizado para escribir en el tópico generators/unit1/control? Fundamentar con referencia a la Nota de Ciberdefensa 1 del Doc. N°16 (configuración por defecto de Eclipse Mosquitto).

Respuesta A.2 — Capacidad del broker de verificar al emisor

Parte B — Byte de Connect Flags del CONNECT del atacante

El siguiente byte corresponde al campo Connect Flags del paquete MQTT CONNECT enviado por 192.168.10.88 al broker a las 03:17:22. Este campo de 1 byte codifica las opciones de autenticación de la conexión.

```
Byte de Connect Flags: 0x00

Estructura de bits:
Bit 7: Username flag   | Bit 6: Password flag  | Bit 5: Will Retain
Bit 4-3: Will QoS     | Bit 2: Will flag       | Bit 1: Clean Session | Bit
0: Reservado
```

Bit(s)	Nombre del campo	Valor (0x00)	Análisis de seguridad
7	Username flag	0	El cliente NO envía nombre de usuario. Sin nombre de usuario, el broker no puede verificar la identidad del cliente. Impacto: ? (en relación a allow_anonymous)
6	Password flag	0	El cliente NO envía contraseña. ¿Qué ocurre cuando el broker tiene allow_anonymous=true y ningún cliente envía credenciales?
5	Will Retain	0	El cliente no tiene mensaje de «Last Will» con retain. ¿Qué significaría Will Retain=1 en el contexto de la función LWT del Doc. N°16?

Bit(s)	Nombre del campo	Valor (0x00)	Análisis de seguridad
4–3	Will QoS	00	QoS 0 para el mensaje LWT (si existiera). Sin garantía de entrega.
2	Will flag	0	No hay mensaje de Last Will configurado en esta conexión.
1	Clean Session	0	Sesión persistente: el broker mantiene las subscripciones del cliente, aunque éste se desconecte. ¿Qué implicancia tiene esto para las subscripciones del atacante?

Pregunta complementaria B.1: El atacante se conecta con Username flag=0 y Password flag=0. El broker acepta la conexión. ¿Qué parámetro de configuración de Eclipse Mosquitto habilita este comportamiento? Indicar el parámetro exacto y su valor. Referencia: Nota de Ciberdefensa 1, Doc. N°16.

Respuesta B.1 — Parámetro de Mosquitto que habilita la conexión sin credenciales

Tarea 1.2 — Predicciones previas al análisis del PCAP

Responder únicamente a partir del conocimiento del Doc. N°16. No abrir el PCAP todavía.

a) En una red IIoT correctamente configurada, ¿cuántas IPs distintas deberían aparecer enviando paquetes MQTT PUBLISH al broker con tópicos de control (patrón: generators/+/control)? Justificar e indicar qué control específico del broker impediría que una IP no autorizada publique en esos tópicos (Sección 2.2, Doc. N°16, función Publish sin autenticación).

Respuesta 1.2a — IPs autorizadas para PUBLISH en tópicos de control

b) Si un atacante sigue la secuencia CONNECT (sin credenciales) → SUBSCRIBE “#” → PUBLISH con RETAIN → DISCONNECT, ¿qué función MQTT de la Tabla de la Sección 2.2 del Doc. N°16 explota en cada paso? Completar la columna de función explotada e indicar la contramedida del documento para cada una.

Paso	Acción del atacante	Función MQTT explotada (Sección 2.2, Doc N°16)	Contramedida del documento
1	CONNECT sin username ni password al puerto 1883		
2	SUBSCRIBE “#” (wildcard a todos los tópicos)		
3	PUBLISH con RETAIN en tópico de control		

Paso	Acción del atacante	Función MQTT explotada (Sección 2.2, Doc N°16)	Contramedida del documento
4	DISCONNECT abrupto antes de que el operador detecte la anomalía		

c) ¿Qué información del proceso podría obtener el atacante durante el período de SUBSCRIBE "#"? Listar al menos cuatro tipos de datos específicos visibles en los tópicos de telemetría de los generadores. ¿A qué fase del marco ATT&CK for ICS equivale esta operación? Referencia: Sección 2.2, Doc. N°16, función wildcard.

Respuesta 1.2c — Información obtenida con SUBSCRIBE "#" y equivalencia ATT&CK

FASE 2 — VERIFICAR (análisis del archivo PCAP en CloudShark)

Configuración inicial (completar una sola vez)

7. Descargar el archivo *base_tecnica_norte_mqtt_20260601.pcap* desde la sección AP N°16 en Moodle.
8. Ingresar a **https://www.cloudshark.org**. Registrar cuenta gratuita si aún no se dispone de una (solo requiere dirección de correo).
9. Hacer clic en «Upload» y seleccionar el archivo PCAP descargado. CloudShark asignará una URL única a la captura.
10. Verificar que el panel «Packet List» muestre paquetes con columna Protocol = «MQTTv3.1.1» para los intercambios sobre puerto TCP 1883. Esto confirma que el disector de MQTT está activo.
11. Incluir en la entrega la URL de CloudShark de tu captura (formato: cloudshark.org/captures/xxxxxxxx).

ETAPA A — Inventario inicial del tráfico capturado

Aplicar filtro: `mqtt`

a) ¿Cuántos paquetes resultan del filtro? Identificar cuántos son de tipo CONNECT (msgtype==1), PUBLISH (msgtype==3) y SUBSCRIBE (msgtype==8). Incluir captura de pantalla.

Respuesta A.a — Total de paquetes MQTT por tipo

b) Observar la columna «Source». Listar TODAS las IPs que aparecen enviando paquetes MQTT con destino al puerto 1883 del broker (192.168.10.5). ¿Cuántas IPs distintas envían tráfico al broker? Indicar si alguna no pertenece al inventario de activos de la topología.

Respuesta A.b — IPs conectadas al broker y anomalías de inventario

c) Completar la tabla de inventario a partir del análisis visual del tráfico:

IP Origen	Rol según inventario	Tipos de paquetes observados (CONNECT/ PUBLISH/SUBSCRIBE)	Tópicos MQTT observados	Cantidad aprox. de paquetes
`192.168.10.20`				
`192.168.10.30`				
`192.168.10.31`				
`192.168.10.32`				
`192.168.10.88`				

ETAPA B — Aislamiento del paquete de ataque con flag RETAIN

Aplicar filtro: `mqtt.retain == 1`

a) ¿Cuántos paquetes muestra el filtro? ¿Cuál es la IP origen del paquete PUBLISH con RETAIN? ¿Coincide con la IP del EMS autorizado (192.168.10.20)? Incluir captura de pantalla del panel Packet List con el filtro activo.

Respuesta B.a — Paquetes con RETAIN activo e IP origen

b) Expandir el árbol de protocolo del paquete PUBLISH con RETAIN en el panel de detalles. Identificar e indicar: (1) el nombre del tópico (Topic Name); (2) el payload completo; (3) el timestamp exacto del paquete. Comparar con la decodificación de la Tarea 1.1, Parte A: ¿coinciden los campos con la trama hex analizada?

Respuesta B.b — Detalles del PUBLISH con RETAIN y verificación con Tarea 1.1

Aplicar filtro adicional: `mqtt.msgtype == 1 and ip.src == 192.168.10.88`

c) Expandir el paquete CONNECT del atacante (192.168.10.88). En el panel de detalles, localizar el campo «Connect Flags». ¿El bit «Username flag» (bit 7) está en 0 o en 1? ¿El bit «Password flag» (bit 6) está en 0 o en 1? Contrastar con el análisis de la Tarea 1.1, Parte B.

Respuesta B.c — Connect Flags del atacante: verificación de credenciales

Aplicar filtro adicional: `mqtt.msgtype == 8 and ip.src == 192.168.10.88`

d) ¿El atacante envió un paquete SUBSCRIBE? Expandirlo y verificar el Topic Filter. ¿Qué wildcard usó? ¿Cuántos tópicos distintos quedan cubiertos por ese Topic Filter? ¿Qué nombre recibe esta técnica según la Sección 2.2 del Doc. N°16? Incluir captura de pantalla del Topic Filter expandido.

Respuesta B.d — SUBSCRIBE del atacante: wildcard y cobertura de tópicos

ETAPA C — Reconstrucción de la secuencia del atacante

Aplicar filtro: `ip.src == 192.168.10.88`

Este filtro muestra TODOS los paquetes enviados por la IP no autorizada. Ordenar por columna Time (creciente) para ver la secuencia cronológica.

a) Completar la siguiente tabla cronológica con los paquetes del atacante (incluir solo los de tipo CONNECT, SUBSCRIBE y PUBLISH, omitir ACKs TCP):

Hora (HH:MM:SS)	Tipo MQTT (mensaje)	Parámetros principales (tópico, payload, flags)	Función MQTT explotada (nombre según Doc N°16)	¿Qué objetivo persigue el atacante en este paso?

Hora (HH:MM:SS)	Tipo MQTT (mensaje)	Parámetros principales (tópico, payload, flags)	Función MQTT explotada (nombre según Doc N°16)	¿Qué objetivo persigue el atacante en este paso?

b) Calcular el intervalo en segundos entre el paquete CONNECT (paso 1) y el paquete PUBLISH con RETAIN (ataque). ¿Qué inferencia se puede hacer sobre el nivel de preparación del atacante? ¿Pudo haber realizado reconocimiento previo fuera de la ventana temporal del PCAP?

Respuesta C.b — Intervalo CONNECT→PUBLISH y nivel de preparación del atacante

c) Aplicar filtro `mqtt.msgtype == 3 and ip.src == 192.168.10.88` para aislar los PUBLISH del atacante durante el período de reconocimiento (antes del paquete con RETAIN). Expandir uno de esos paquetes: ¿publicó el atacante mensajes en tópicos de telemetría de los generadores, o solo subscribió y escuchó? ¿Qué datos de proceso había publicado el EMS en esos tópicos durante el período de reconocimiento que el atacante pudo leer?

Respuesta C.c — Datos de proceso leídos durante el reconocimiento

d) Aplicar filtro `ip.src == 192.168.10.30` y localizar el primer paquete del Sensor-GEN-01 posterior al DISCONNECT del atacante. ¿Cuántos segundos después del ataque se reconectó el sensor? ¿Qué fue lo primero que recibió al reconectarse y por qué (relacionar con el mecanismo del retained message del Doc. N°16)?

Respuesta C.d — Reconexión del Sensor-GEN-01 y entrega del retained message

FASE 3 — COMPRENDER (síntesis analítica y propuesta de contramedidas)

Las preguntas de esta fase requieren argumentación fundamentada. Cada respuesta debe citar la sección específica del Doc. de Cátedra N°16 que respalda el análisis. Las respuestas que no incluyan referencia explícita al documento no son elegibles para puntaje completo.

1. ¿Cuál de los cuatro desafíos estructurales del ecosistema IoT/IIoT (Sección 4, Doc. N°16) habilitó directamente que la IP 192.168.10.88 pudiera conectarse al broker sin credenciales y publicar en el tópico generators/unit1/control sin ser rechazada? Citar textualmente el nombre del desafío, describir su mecanismo técnico tal como lo define el documento, y explicar por qué este desafío es «estructural» y no remedable con un simple cambio de configuración del sensor.

Respuesta 1 — Desafío estructural que habilitó el ataque

2. Diseñar la configuración segura del broker MQTT de Base Técnica Norte. Especificar las tres condiciones de la Nota de Ciberdefensa 1 del Doc. N°16 y traducirlas a parámetros concretos de configuración de Eclipse Mosquitto: (a) el parámetro que impide conexiones anónimas; (b) la estructura de ACLs que impide que 192.168.10.88 publique en tópicos de control y que impide el SUBSCRIBE con wildcard “#”; (c) el parámetro y puerto que habilita TLS para el canal. Para cada uno, indicar si su ausencia en la configuración actual es el mecanismo técnico que el atacante explotó.

Respuesta 2 — Configuración segura del broker: tres condiciones de la Nota de Ciberdefensa 1

3. Comparar el impacto del ataque SUBSCRIBE “#” (reconocimiento por wildcard MQTT) con el impacto del ataque FC43 Read Device Identification de Modbus TCP analizado en AP N°12. Responder: (a) ¿cuál de los dos provee mayor volumen de información al atacante sobre el proceso industrial y por qué?; (b) ¿en qué se diferencia la contramedida técnica: qué puede bloquear un firewall industrial con DPI de Modbus que un broker MQTT con ACLs no puede hacer, y viceversa?; (c) ¿cuál de los dos ataques deja más evidencia forense en los logs del sistema y por qué?

Respuesta 3 — Comparación SUBSCRIBE “#” (MQTT) vs. FC43 (Modbus): impacto y contramedida

4. El paquete retained message ({“cmd”:”SHUTDOWN”}) persistió en el broker después de que el atacante se desconectó (03:22:48). El Sensor-GEN-01 lo recibió al reconectarse (03:24:15): 87 segundos después del ataque. Explicar: (a) por qué un IDS/SIEM que monitorea tráfico de red en tiempo real NO habría detectado este vector en el momento del daño, solo en el del ataque; (b) qué mecanismo de monitoreo específico debería implementarse sobre el broker para detectar un retained message malicioso antes de que ningún sensor se reconecte; (c) relacionar la respuesta con la contramedida de la Sección 2.2 del Doc. N°16 para la función Retained messages.

Respuesta 4 — Persistencia del retained message: detección y ventana temporal

5. El broker MQTT (192.168.10.5) está en la red IIoT de Base Técnica Norte junto con los sensores (Level 1/2 del Modelo Purdue). Proponer tres controles de arquitectura IT/OT que, combinando los Documentos N°15 y N°16, habrían prevenido o detectado el ataque sin deshabilitar la funcionalidad de telemetría del sistema IIoT. Para cada control: (a) nombrar el componente arquitectónico (ej. «DMZ 3.5», «segmentación de VLAN IIoT», «proxy MQTT»); (b) describir exactamente qué paso del ataque habría prevenido o detectado; (c) referenciar la sección del Doc. N°15 o N°16 que fundamenta el control propuesto.

Respuesta 5 — Tres controles de arquitectura IT/OT y su efecto sobre la cadena de ataque

CRITERIOS DE ENTREGA

Componente	Puntaje	Descripción
Fase 1 — Predecir	20 pts	Tarea 1.1: tabla de decodificación PUBLISH completa con preguntas A.1 y A.2 (6 pts), tabla de Connect Flags con pregunta B.1 (4 pts). Tarea 1.2: tres predicciones con tabla de funciones MQTT (10 pts). Total 20 pts.
Fase 2 — Verificar (Etapa A)	15 pts	Inventario de tráfico MQTT completo con capturas de pantalla. URL de CloudShark obligatoria para validar la entrega. Tabla de inventario por IP completa (15 pts).
Fase 2 — Verificar (Etapas B+C)	25 pts	Etapa B: aislamiento del paquete RETAIN con verificación contra Tarea 1.1, Connect Flags y SUBSCRIBE wildcard con capturas (12 pts). Etapa C: tabla cronológica completa con funciones MQTT, intervalo de ataque, datos de reconocimiento y análisis del retained message en Sensor-GEN-01 (13 pts).
Fase 3 — Comprender (5 preguntas)	40 pts	Pregunta 1: 7 pts. Preguntas 2, 3 y 4: 8 pts c/u. Pregunta 5: 9 pts. Cada respuesta debe referenciar la sección del Doc. N°16 (o N°15 en la pregunta 5) que la fundamenta. Sin referencia explícita: puntaje máximo 50% por pregunta.
TOTAL	100 pts	Subir UNA sola entrega en PDF con capturas de pantalla integradas. Formato del archivo: APELLIDO_AP16_CiberTO2026.pdf